ADR-0006 · Decisiones del Sprint 5 (cierre del MVP)

Fecha: 2026-10-29 · Estado: aceptada

Alcance (spec §13): importación y exportación CSV (HU07, HU08), permisos, backup restaurado, despliegue HTTPS (HU10), firma del instalador si aplica, manual y demo.

Decisiones

#	Decisión	Motivo
1	Importación en **dos pasos sin estado**: `preview` y `commit` reciben el mismo archivo; `commit` vuelve a validar todo. No se guarda el archivo entre pasos.	Evita almacenar archivos temporales con datos de clientes (§8) y garantiza que se confirma exactamente lo que se previsualizó.
2	CSV con el módulo `csv` de Python y validación propia por fila, **sin pandas**.	5.000 filas no lo justifican; pandas agrega ~60 MB a la imagen. Desvío menor del §8.
3	Formato del §10 y, además, tolera lo que genera Excel en español: separador `;`, BOM y coma decimal **sin** separador de miles. `description` es opcional.	Menos rechazos por formato con el mismo contrato.
4	**Idempotencia** por cliente + número: una fila que ya existe se rechaza como "ya existe", así confirmar dos veces no duplica. La restricción `UNIQUE` cubre las cargas simultáneas (409 `import_conflict`).	§10.
5	Clientes inexistentes: se **rechazan por defecto**; con `create_missing_clients` se crean (solo los que tienen al menos una fila válida). Clientes inactivos: siempre se rechazan.	§10 "o dar opción explícita de crearlos"; coherente con ADR-0002 #14.
6	Cada confirmación registra un `import_batch` (filas, importadas, rechazadas, estado) y un evento de auditoría.	§7 y §3.
7	`GET /exports/invoices.csv` usa **la misma consulta y los mismos filtros** que `GET /invoices` (función compartida), sin paginar y con un tope de 50.000 filas. Las primeras 6 columnas son las de importación.	HU08. El archivo exportado puede reimportarse en otra instalación.
8	Protección contra **inyección de fórmulas** en CSV: los textos que empiezan con `= + - @` se exportan con apóstrofo.	Un nombre de cliente malicioso no ejecuta fórmulas al abrir el archivo en Excel.
9	**Matriz de permisos automática**: un test recorre todas las rutas; las privadas deben responder 401 sin token y las de administrador 403 al operador. Una ruta nueva sin clasificar hace fallar el test.	Checklist §18 "Login y roles verificados".
10	Backup con `pg_dump -Fc` + SHA-256 en un script Python sin dependencias (`--via docker` en Windows, igual en el servidor). La **verificación restaura en una base temporal y compara** conteos, totales y versión del esquema.	§8 y §11: "backup restaurado" demostrable, no solo generado.
11	Producción en **una EC2 con Docker Compose y Caddy** como proxy HTTPS (certificados de Let's Encrypt automáticos). Solo quedan expuestos los puertos 80 y 443. Reemplaza la carpeta `infra/nginx` prevista en §14.	§8 "HTTPS terminado por proxy". Caddy renueva certificados sin cron ni certbot.

#	Decisión	Motivo
12	Backups a **S3 con SSE-KMS**: política del bucket que exige TLS y cifrado KMS, bloqueo de acceso público, versionado y ciclo de vida. La instancia usa un **rol IAM** de mínimo privilegio, sin claves guardadas.	§8 "bucket S3 para backups cifrados".
13	**Firma de código opcional**: `build-desktop.ps1 -Sign` usa `signtool` con un certificado OV/EV del proveedor (por huella o `.pfx` en variables de entorno, nunca en Git) y sello de tiempo.	§13 "instalador firmado si aplica": requiere comprar un certificado.
14	El escritorio valida HTTPS contra el **almacén de certificados de Windows** (`truststore`).	Funciona detrás de proxies corporativos con inspección TLS y con CAs propias.
15	Versión **1.0.0** (API y escritorio).	Cierre del MVP.

Pendiente (post-MVP)

- Comprar el certificado de firma de código y firmar el instalador.
- Ejecutar el despliegue real (HU10) y registrar la prueba de restauración en producción.
- Monitoreo con alarma de CloudWatch sobre el estado de la instancia (opcional).